

A perspective view of a server room aisle. The floor is dark and reflective, with glowing blue energy lines or data streams flowing down the center of the aisle. The server racks on both sides are dark with some blue lights visible. The ceiling has a grid of lights.

AI-Driven Sensitive Data Discovery for Secure DevSecOps and Privacy Compliance

Practical engineering patterns for continuous sensitive data visibility, automated governance, and privacy risk detection across distributed cloud-native systems.

Presented by Mary Sirisha Duggimpudi

Senior Software Engineer

The Challenge: Sensitive Data Is Everywhere

Cloud Services

Regulated data distributed across S3, RDS, BigQuery, and managed SaaS APIs

Operational Databases

Schema changes, migrations, and ad-hoc tables that escape classification

Logs & Telemetry

PII and secrets leaking into observability pipelines and analytics platforms

Hybrid Infrastructure

On-prem residue, edge nodes, and hybrid endpoints outside standard inventory

Manual discovery and periodic compliance reviews cannot scale to match the velocity and complexity of modern distributed systems.

Why Manual Discovery Fails at Scale

The Visibility Gap

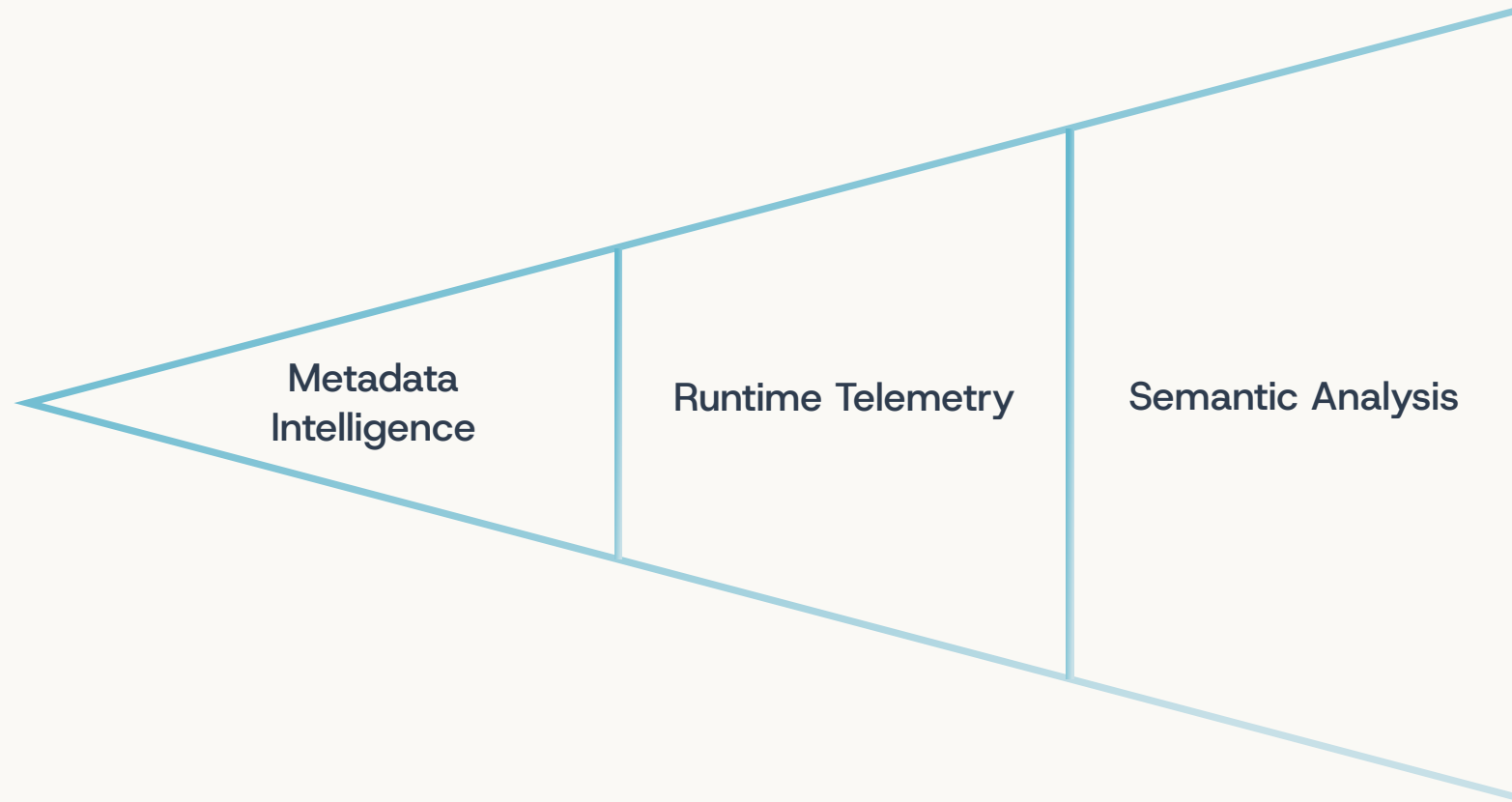
Point-in-time audits miss ephemeral resources, short-lived containers, and data copies created during incident response or feature development. Schema drift and microservice proliferation widen the gap between what compliance teams document and what systems actually contain.

The Ownership Problem

In distributed architectures, no single team owns the full data surface. Regulated fields appear in caches, message queues, feature stores, and third-party integrations - rarely catalogued, often forgotten.

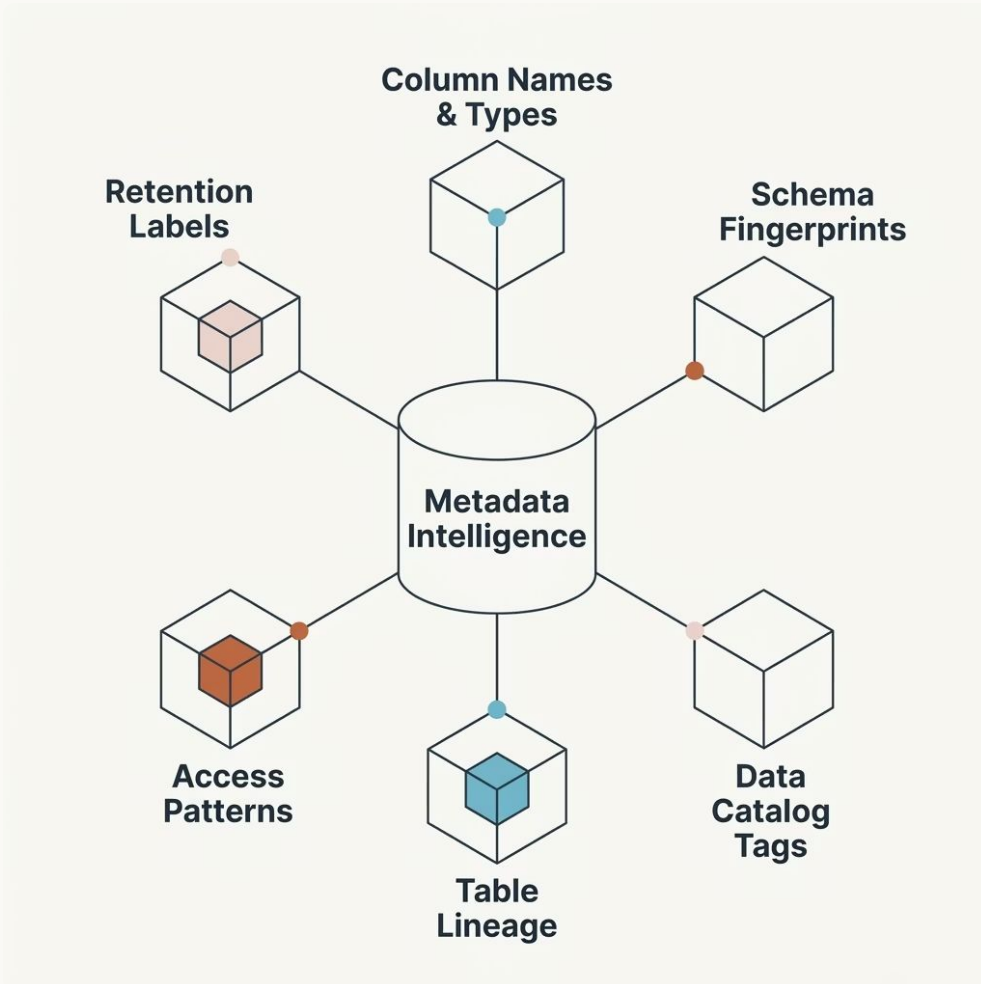


A Four-Layer Discovery Pipeline



Each layer contributes independent signal; together they produce high-confidence, continuously updated sensitive data inventory across the full system surface.

Layer 1: Metadata Intelligence



Signal Before Sampling

Metadata signals provide high-recall, low-cost pre-screening before any data is read. Column names, data types, lineage graphs, and catalog tags allow the pipeline to prioritize scan targets and reduce false positive rates downstream.

- Schema fingerprinting detects structural similarity to known sensitive schemas
- Lineage traversal surfaces derived tables inheriting regulated fields
- Access pattern anomalies flag undiscovered stores receiving sensitive traffic

Layer 2: Semantic Analysis & ML Classification

Deterministic Rules

Regex patterns and checksum validators for structured types: SSNs, PANs, IBANs, passport numbers. High precision, low recall on obfuscated or encoded fields.

ML Classifiers

Fine-tuned models trained on labeled enterprise data recognize sensitive context even when field names are opaque or data is partially masked. Confidence scores drive triage priority.

NLP Entity Detection

Named entity recognition extracts PII from unstructured fields - support tickets, comments, JSON blobs - that deterministic rules cannot reach.

- ❏ Hybrid ML + deterministic design is critical: neither approach alone achieves acceptable precision and recall in enterprise environments.

Layer 3: Runtime Telemetry

Static scans miss what data *flows* through systems at runtime. Instrumenting API gateways, service meshes, and database query logs closes the gap between stored data and data-in-motion.



API Trace Analysis

eBPF-based or sidecar agents sample payloads at the service mesh layer, identifying sensitive fields crossing service boundaries without full packet capture.



Query Log Mining

Database audit logs reveal SELECT patterns on sensitive columns, surfacing shadow access paths and ad-hoc exports that bypass governance controls.



Log Scrubbing Validation

Continuous sampling of application logs verifies that scrubbing and masking controls are functioning, catching regressions introduced by dependency updates or config drift.



Tackling False Positives & Explainability

The Trust Problem

Discovery pipelines that cry wolf erode engineer trust quickly. Teams begin ignoring alerts, and real findings get buried. Explainability is not a nice-to-have - it is an adoption prerequisite.

- Surface evidence samples, not just labels
- Expose confidence scores and contributing signals
- Allow domain teams to submit feedback that retrains classifiers



Auto-Remediate

Human Review

Model Feedback

Handling Schema Drift & Distributed Ownership

1

Detect

Schema change events from DDL logs or catalog webhooks trigger incremental re-scans scoped to affected tables

2

Classify

New columns receive automated classification within the CI/CD pipeline before reaching production

3

Assign

Ownership metadata from service catalogs routes findings to the responsible team's backlog automatically

4

Govern

Policy-as-code enforces data handling requirements and blocks non-compliant deployments at the gate

From Discovery to Automated Remediation

Closing the Loop

Discovery findings are only valuable when they drive action. Integrating the pipeline with ticketing, CI/CD gates, and policy engines converts passive inventory into active governance.

- **Jira / GitHub Issues:** Auto-create remediation tickets with evidence and SLA tags
- **OPA / Sentinel:** Block deployments that introduce unclassified sensitive stores
- **Vault / KMS integration:** Trigger encryption-at-rest validation for newly discovered fields
- **Evidence packages:** Auto-generate audit artifacts for SOC 2, GDPR, and HIPAA reviews

Workflow Triggers

High-severity findings - PagerDuty incident

New PII in schema diff - PR comment + block

Unencrypted sensitive store - Vault provisioning workflow

Quarterly audit - Evidence bundle auto-export

Integrating Discovery into CI/CD Delivery Pipelines

01

Pre-commit hooks

Lightweight classifiers scan migration files and config changes for hardcoded secrets and sensitive field additions before code reaches the repo

02

Pull request analysis

Schema diffs trigger classification jobs; findings surface as inline PR comments with remediation guidance linked to internal policy docs

03

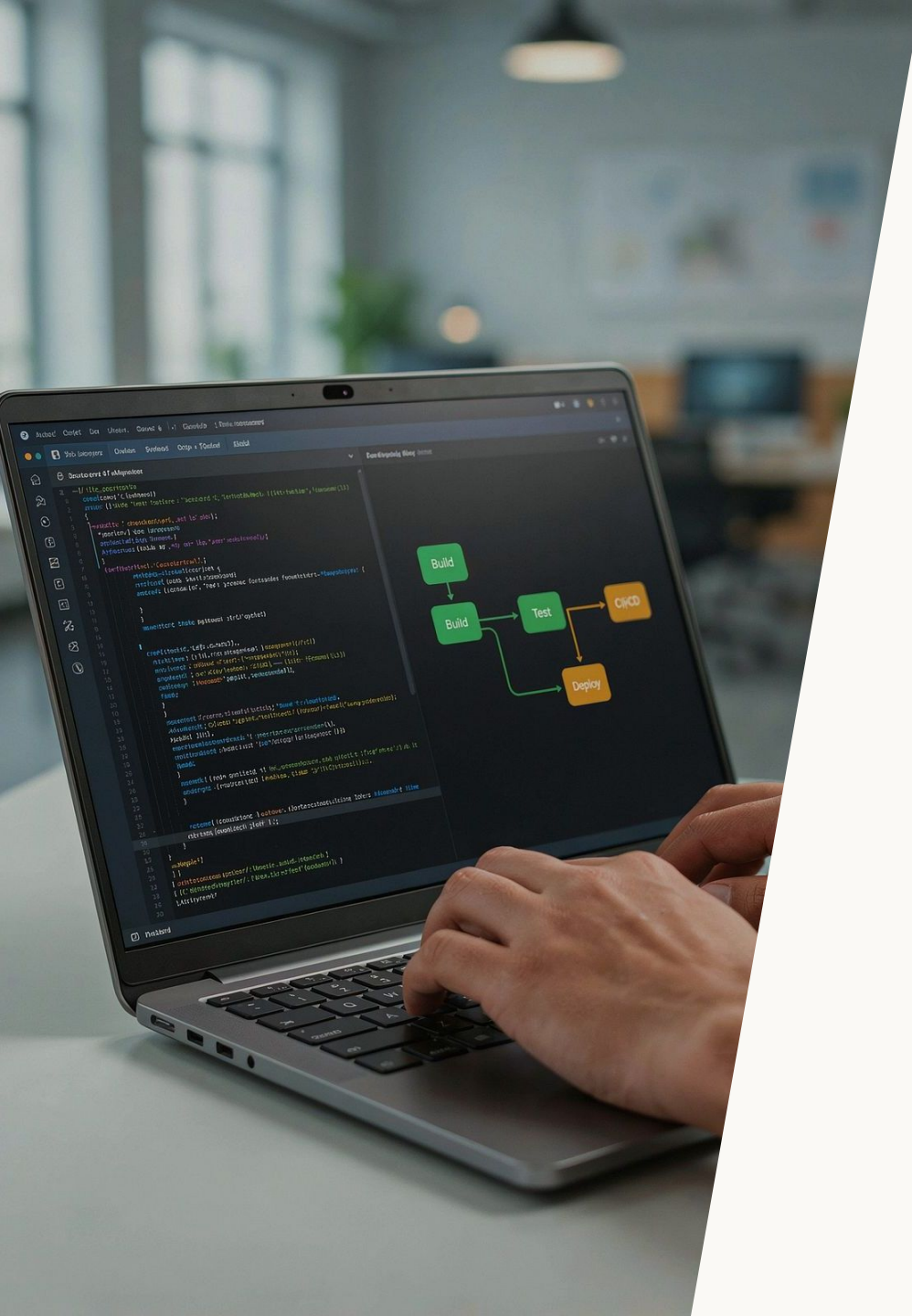
Deployment gates

OPA policies enforce that every new data store carrying sensitive fields has a corresponding classification record, encryption attestation, and retention label before promotion

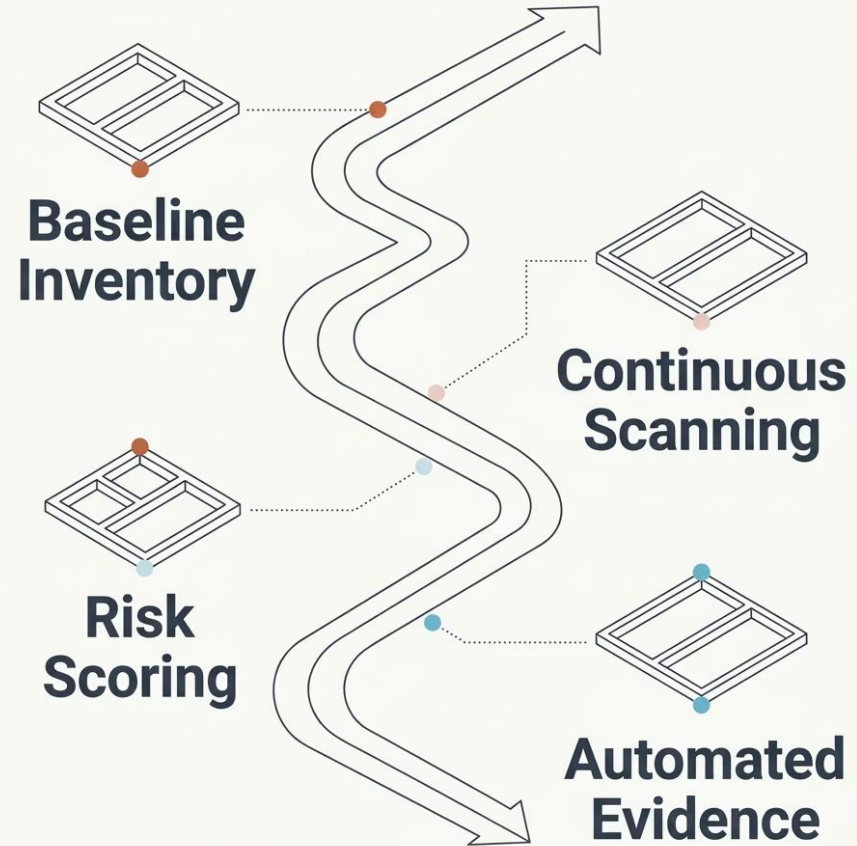
04

Post-deploy drift detection

Production scans run on a continuous schedule; deviations from the approved inventory trigger alerts to the owning team within minutes



Privacy Risk Detection Without Manual Audits



Risk-Stratified Coverage

Not all sensitive data carries equal regulatory risk. The discovery pipeline applies jurisdiction-aware risk scoring, weighting GDPR special categories, HIPAA PHI, and PCI-DSS cardholder data differently, so remediation effort is prioritized where regulatory exposure is highest.

LESSONS LEARNED

Key Engineering Trade-offs

Coverage vs. Cost

Full content scanning is expensive. Metadata-first triage reduces scan volume by 60-80% in practice while preserving high recall on high-risk stores.

Precision vs. Recall

Tuning thresholds for regulated environments favors recall. Accept more false positives in automated triage; invest in fast human review workflows for edge cases.

Automation vs. Explainability

Fully automated remediation requires high model confidence. Expose reasoning artifacts to engineers - findings that engineers understand get fixed; black-box alerts get ignored.

Reusable Patterns: What to Take Back to Your Team



Discovery Pipeline Blueprint

Metadata, semantic, and runtime telemetry layering, deployable as Kubernetes jobs or Lambda functions with configurable scan schedules



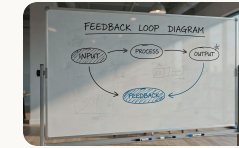
Policy-as-Code Templates

OPA rego rules and Sentinel policies for blocking unclassified sensitive stores at CI/CD gates, ready to fork and adapt



Evidence Automation

Automated artifact generation for SOC 2 CC6, GDPR Article 30, and HIPAA §164.312, reducing audit prep from weeks to hours



Human-in-the-Loop Feedback

Classifier retraining loops that incorporate domain-team feedback, continuously improving precision without full retraining cycles

Toward Intelligent, Automated Data Governance

The destination is a system that **knows what sensitive data it holds, where it flows, who owns it, and whether controls are functioning** - continuously, without manual intervention.

Continuous Visibility

Inventory that stays current as systems evolve, not just at audit time

Operational Resilience

Governance failures surface as operational signals, not compliance findings discovered months later

Engineer-Native Workflows

Privacy and security controls embedded in delivery pipelines, not bolt-on processes that slow teams down



Thank You

